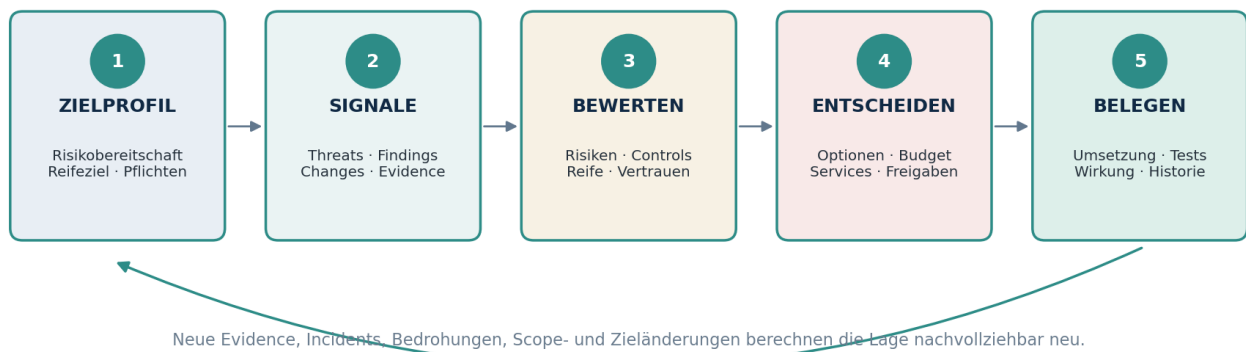


Reifegrad, Risiken, Bedrohungen & Control Intelligence

Erklärbare Bewertungs-, Vertrauens- und Entscheidungslogik für ein lebendes, zielorientiertes ISMS.

Risk & Control Intelligence: ein erklärbarer Lern- und Entscheidungszyklus



ARBEITSBEZEICHNUNG ISMS Managed Service Platform
VERSION 1.0 | **STATUS** Erstellt | **STAND** 21.07.2026
ABHÄNGIGKEITEN Dokument 00 bis 08

Dokumentauftrag & Verbindlichkeit

Dokument 09 ist die kanonische fachliche Quelle für Reifegrad-, Risiko-, Threat-, Control- und Confidence-Logik. Nachfolgende Dokumente dürfen diese Modelle visualisieren, technisch implementieren oder profilspezifisch konfigurieren, aber nicht still semantisch verändern.

Steuerungsfeld	Festlegung
Dokument-ID	09
Status	Erstellt - Version 1.0
Owner	Product Architecture / ISMS Method Owner
Gültigkeit	Bis zur freigegebenen Nachfolgeversion
Änderungskontrolle	Methoden-, Gewichtungs- und Schwellenänderungen benötigen Version, Begründung, Impactanalyse und Freigabe.
Zentrale Nachfolger	Dokument 10, 17, 18, 19, 20A und 20C

Inhalt

1 Auftrag · 2 Executive Summary · 3 Prinzipien · 4 Strategie-DNA · 5 bis 7 Reife und Confidence · 8 bis 11 Risiko · 12 bis 14 Threat/Vulnerability · 15 bis 17 Control Intelligence · 18 Zielerreichung/Readiness · 19 Benchmarking · 20 Erklärbarkeit · 21 KI-Grenzen · 22 Rollen · 23 Szenarien · 24 bis 32 Governance und Übergaben

1. Dokumentauftrag und Abgrenzung

Dieses Dokument definiert die fachliche Intelligenzschicht zwischen dem digitalen Unternehmenszwillings aus Dokument 07, den ISMS-Prozessen aus Dokument 08 und dem Decision Center aus Dokument 10. Es legt fest, wie Zielprofile, Reifegrade, Risiken, externe und interne Signale, Control-Abdeckung, Control-Wirksamkeit, Readiness, Datenvertrauen und Handlungsempfehlungen modelliert, berechnet, erklärt, freigegeben und historisiert werden.

Nicht festgelegt werden hier das endgültige visuelle Dashboarddesign, Portfolio- und Investitionssimulationen im Detail, technische Konnektoren, physische Datenbanktechnologie oder konkrete KI-Modelle. Diese Themen folgen in Dokument 10, 17, 18 und 20A. Dokument 09 definiert jedoch die fachlichen Verträge, die diese Komponenten einhalten müssen.

Die Modelle sind konfigurierbare Managementhilfen und keine naturwissenschaftliche Messung von Sicherheit. Numerische Werte dienen Vergleich, Priorisierung, Trend und Simulation. Sie dürfen nicht als Garantie, Zertifizierungsurteil oder objektive Schadensprognose dargestellt werden.

2. Executive Summary

Die Plattform führt vier heute häufig vermischte Fragen bewusst auseinander:

1. **Reife:** Wie gut ist eine Fähigkeit entworfen, umgesetzt, betrieben und verbessert?
2. **Risiko:** Welches unerwünschte Szenario kann eintreten, wie wahrscheinlich bzw. plausibel ist es und welche geschäftliche Wirkung hätte es?
3. **Control Intelligence:** Welche Schutzwirkung liefern vorhandene Controls im konkreten Scope tatsächlich?
4. **Vertrauen:** Wie vollständig, aktuell, unabhängig und nachvollziehbar ist die Datengrundlage der Aussage?

Aus diesen Dimensionen entsteht keine einzige magische Sicherheitszahl. Die Plattform bildet stattdessen einen **erklärbaren Entscheidungsraum**: Zielzustand, aktueller Zustand, relevante Veränderungen, Ursachen, Handlungsoptionen, erwartete Wirkung, Kosten, Abhängigkeiten und Confidence. Kunden können unterschiedliche Zielprofile verfolgen - etwa ein pragmatisches Mindestniveau, einen definierten Reifegrad, eine regulatorische Pflichterfüllung, Zertifizierungsbereitschaft oder ein resilienzorientiertes Unternehmensziel.

Bedrohungen werden nicht pauschal auf alle Kunden verteilt. Ein Signal wird erst relevant, wenn technische oder organisatorische Anwendbarkeit, betroffene Assets, Geschäftsbezug, Exposition und Control-Lücken zusammenpassen. Danach entsteht ein nachvollziehbarer Pfad: Signal -> Relevanz -> Risikoszenario -> Control-Impact -> Entscheidung -> Maßnahme oder Managed Service -> Wirksamkeitsprüfung.

3. Verbindliche Modellprinzipien

- **M01 - Keine Einzahl-Wahrheit:** Ein Gesamtwert darf Details verdichten, aber nie Reife, Risiko, Wirksamkeit und Confidence ununterscheidbar vermischen.
- **M02 - Ziel vor Score:** Bewertung erfolgt immer relativ zu kundenspezifischem Scope, Zielprofil, Risikobereitschaft und Zeithorizont.
- **M03 - Evidence vor Selbstauskunft:** Behauptete Implementierung und belegte Wirksamkeit sind unterschiedliche Zustände.
- **M04 - Erklärbare Berechnung:** Jede Bewertung besitzt Methode, Version, Eingaben, Gewichtung, Ausnahmen, Datenstand und verantwortlichen Owner.
- **M05 - Confidence getrennt anzeigen:** Ein hoher Score bei schwacher Datenlage wird sichtbar abgeschwächt, nicht still als sicher dargestellt.
- **M06 - Ereignisgetriebene Neubewertung:** Threats, Incidents, Findings, Scope Changes, neue Evidence und ablaufende Ausnahmen können Bewertungen sofort verändern.
- **M07 - Menschliche Übersteuerung:** Autorisierte Nutzer dürfen Vorschläge ändern, müssen aber Begründung und Gültigkeit dokumentieren.
- **M08 - Keine automatische Risikoakzeptanz:** Regeln und KI dürfen vorbereiten, niemals wesentliche Akzeptanzen oder Managementfreigaben ersetzen.
- **M09 - Proportionalität:** Kleine, wenig regulierte Kunden können vereinfachte Modelle nutzen; hochkritische oder regulierte Scopes erhalten mehr Tiefe und Kontrollen.
- **M10 - Historische Rekonstruktion:** Jeder relevante Score muss für einen früheren Stichtag mit damaliger Methode und Datenlage reproduzierbar sein.
- **M11 - Kein verstecktes Upselling:** Serviceempfehlungen werden aus fachlichem Bedarf abgeleitet und zeigen auch interne oder alternative Behandlungswege.
- **M12 - Kernlogik ohne generative KI:** Bewertungen und Statusübergänge funktionieren deterministisch; KI darf erklären, strukturieren und Vorschläge erzeugen.

- **M13 - Keine Scheingenauigkeit:** Prozentwerte werden nur verwendet, wenn Skala, Bandbreite und Bedeutung verständlich sind.
- **M14 - Kalibrierung statt Dogma:** Referenzgewichtungen sind Startwerte und werden anhand Zielprofil, Kundenerfahrung und Validierung versioniert angepasst.
- **M15 - Vergleich nur bei Vergleichbarkeit:** Benchmarks zeigen Population, Scope, Datenqualität und Methodenversion.

Vier getrennte Aussagen - erst gemeinsam entsteht eine belastbare Steuerung



4. Strategie-DNA und Zielprofile

Die **Strategie-DNA** beschreibt, wie ein Kunde Informationssicherheit steuern will. Sie ist keine Marketingpersona, sondern eine versionierte Konfiguration, die Schwellenwerte, Priorisierung, Tiefe und Kommunikationsform beeinflusst.

4.1 Pflichtdimensionen der Strategie-DNA

Dimension	Leitfrage	Beispielhafte Ausprägungen
Geschäftsziel	Welchen Geschäftszweck soll das ISMS unterstützen?	Marktzugang, Resilienz, Kundenvertrauen, Zertifizierung, Regulatorik
Scope	Für welche Einheiten, Prozesse und Services gilt das Ziel?	Gesamtes Unternehmen, Produkt, Region, kritischer Service
Zielart	Welcher Zustand wird angestrebt?	Mindestniveau, Reifegrad, Readiness, Risikoreduktion, Resilienz
Risikobereitschaft	Welche Restrisiken sind unter welchen Bedingungen tragbar?	konservativ, differenziert, wachstumsorientiert
Zeithorizont	Bis wann soll der Zielzustand erreicht sein?	Quartal, Geschäftsjahr, Auditdatum, mehrjährige Route
Ressourcenrealität	Welche Mittel stehen zur Verfügung?	Budget, interne Kapazität, Skills, Reise- und Lieferfähigkeit
Delivery-Modell	Was bleibt intern und was wird als Managed Service betrieben?	intern, gemeinsam, überwiegend extern
Nachweistiefe	Wie belastbar müssen Aussagen sein?	Managementsteuerung, Kundenprüfung, Zertifizierung, Aufsicht
Änderungsdynamik	Wie häufig verändern sich Scope und Bedrohungslage?	stabil, saisonal, schnell wachsend, M&A-intensiv
Kommunikationsstil	Welche Verdichtung benötigen Rollen?	Executive, operativ, Audit, technisch

4.2 Zielprofiltypen

- **Baseline-Profil:** Definiertes Mindestniveau für ausgewählte Kernfähigkeiten.

- **Maturity-Profil:** Zielreife je Capability und Termin.
- **Readiness-Profil:** Nachweisbare Vorbereitung auf ein konkretes Audit, Assessment oder regulatorisches Ereignis.
- **Risk-Reduction-Profil:** Senkung definierter Top-Risiken oder Risikokonzentrationen.
- **Resilience-Profil:** Schutz und Wiederherstellungsfähigkeit kritischer Geschäftsservices.
- **Transformation-Profil:** Sicherheitsanforderungen für Cloud, M&A, Produktlaunch oder Organisationsumbau.
- **Hybrid-Profil:** Kombination mehrerer Zieltypen mit expliziter Prioritätsregel.

Ein Kunde kann mehrere Profile parallel führen. Die Plattform benötigt jedoch ein **primäres Steuerungsprofil**, damit tägliche Mission, Eskalationen und Zielroute nicht widersprüchlich werden.

4.3 Zielkonflikte

Typische Konflikte sind maximale Nachweistiefe versus Geschwindigkeit, niedrige Restrisiken versus Budget, lokale Autonomie versus Standardisierung oder schnelle Auditvorbereitung versus nachhaltige Control-Wirksamkeit. Die Plattform markiert Zielkonflikte, erzwingt aber keine mathematisch „optimale“ Entscheidung. Sie zeigt Auswirkungen und fordert eine nachvollziehbare Priorisierung.

5. Kanonisches Reifegradmodell

5.1 Reife ist eine Fähigkeitseigenschaft

Reife wird für eine klar definierte **Capability im Scope** bewertet, nicht pauschal für das gesamte Unternehmen. Beispiele sind Identity Governance, Supplier Security, Incident Management oder Policy Lifecycle. Eine Capability kann mehrere Controls und Prozesse enthalten.

5.2 Referenzskala 0 bis 5

Stufe	Bezeichnung	Bedeutung
0	Nicht vorhanden	Fähigkeit ist nicht erkennbar oder liegt außerhalb des bestätigten Scopes.
1	Initial	Einzelne Aktivitäten erfolgen reaktiv, personenabhängig und kaum dokumentiert.
2	Wiederholbar	Grundabläufe existieren und werden teilweise wiederholt, aber uneinheitlich gesteuert.
3	Definiert	Rollen, Prozess, Kriterien und Artefakte sind festgelegt und im Scope überwiegend umgesetzt.
4	Gesteuert	Leistung, Ausnahmen und Wirksamkeit werden gemessen, regelmäßig überprüft und aktiv gesteuert.
5	Adaptiv	Die Fähigkeit lernt aus Daten und Ereignissen, verbessert sich nachweisbar und reagiert frühzeitig auf Veränderungen.

Stufe 5 ist kein automatisches Ziel. Für viele Fähigkeiten ist ein belastbarer Zielwert 3 oder 4 wirtschaftlich angemessener. Die Strategie-DNA legt Zielstufen je Capability fest.

5.3 Vier Bewertungsfacetten

Jede Capability wird mindestens in vier Facetten bewertet:

- **Design:** Sind Zweck, Scope, Rollen, Regeln und Kriterien angemessen definiert?
- **Implementierung:** Ist das Design im relevanten Scope tatsächlich umgesetzt?
- **Betrieb:** Wird die Fähigkeit zuverlässig und wiederholbar ausgeführt?
- **Wirksamkeit:** Belegen Tests, Outcomes und Trends die beabsichtigte Schutzwirkung?

Die Plattform darf eine hohe Reife nicht allein aus Dokumentation ableiten. Ein sehr gutes Design bei schwacher Umsetzung bleibt sichtbar unausgewogen.

5.4 Referenzberechnung

Für Demonstrator und Standardprofil gilt als transparente Ausgangslogik:

$Maturity = 0,20 \times Design + 0,25 \times Implementierung + 0,20 \times Betrieb + 0,35 \times Wirksamkeit$

Alle Facetten liegen zwischen 0 und 5. Das Ergebnis wird auf eine Dezimalstelle angezeigt und zusätzlich als Band interpretiert. Gewichtungen sind versioniert konfigurierbar. Fehlt eine Facette, wird sie nicht still mit null bewertet; stattdessen sinkt Confidence und der Status wird als unvollständig markiert.

5.5 Roll-up und Aggregation

Capability-Werte können zu Domänen und Zielprofilen aggregiert werden. Standardmäßig erfolgt die Aggregation gewichtet nach Kritikalität, Scope-Anteil und Zielrelevanz. Ein arithmetischer Durchschnitt darf kritische rote Bereiche nicht verdecken. Daher werden zusätzlich angezeigt:

- niedrigste kritische Capability,
- Anteil unter Ziel,
- Anzahl unbewerteter kritischer Capabilities,
- größte negative Veränderung,
- systemische Engpässe mit mehreren Abhängigkeiten.

6. Reifegrad-Assessment und Evidence

6.1 Bewertungsarten

- Self Assessment,
- moderiertes Assessment,
- unabhängiges Review,
- Audit- oder Prüfungsfeststellung,
- automatisiert beobachtete Indikatoren,
- Control-Test-Ergebnis,
- kombinierte Bewertung.

Die Bewertungsart beeinflusst Confidence, nicht automatisch den fachlichen Score. Eine unabhängige Prüfung kann einen niedrigen Wert sehr belastbar belegen; eine positive Selbstauskunft kann hohe Reife nur schwach stützen.

6.2 Evidence-Anforderungen

Eine Reifeaussage enthält mindestens Capability, Scope, Facette, Wert, Begründung, Kriterienversion, Evidence-Links, Assessor, Bewertungsdatum, Gültigkeitsdauer und Confidence. Kritische Capabilities benötigen definierte Mindest-Evidence und ggf. Vier-Augen-Freigabe.

6.3 Staleness

Evidence besitzt je Typ eine erwartete Aktualität. Eine Architekturfreigabe kann länger gültig sein als ein monatlicher Kontrollreport. Abgelaufene Evidence löscht den Score nicht automatisch, senkt aber Confidence und erzeugt Reviewbedarf. Materiale neue Ereignisse können eine sofortige Neubewertung erzwingen.

7. Confidence- und Datenvertrauensmodell

Confidence beantwortet: **Wie belastbar ist diese konkrete Aussage für diesen Verwendungszweck?** Es ist keine allgemeine Datenqualitätsampel.

7.1 Dimensionen

Dimension	Leitfrage
Vollständigkeit	Sind die wesentlichen Objekte, Facetten und Quellen abgedeckt?
Aktualität	Ist der Datenstand für den Entscheidungszeitpunkt geeignet?
Herkunft	Ist klar, woher die Information stammt und wie sie verarbeitet wurde?
Unabhängigkeit	Wurde die Aussage nur selbst berichtet oder unabhängig geprüft?
Konsistenz	Widersprechen sich Quellen, Zeitstände oder verbundene Objekte?
Granularität	Passt die Detailtiefe zum Scope und zur Entscheidung?

Dimension	Leitfrage
Methodenstabilität	Ist die Berechnung versioniert und ohne verdeckte Änderung erfolgt?
Integrität	Ist das Artefakt unverändert, autorisiert und technisch vertrauenswürdig?

7.2 Referenz-Confidence

Die Plattform berechnet optional einen Wert von 0 bis 100 aus den acht Dimensionen. Die Nutzeroberfläche zeigt zusätzlich das Band:

- **hoch:** belastbar für die vorgesehene Entscheidung,
- **mittel:** nutzbar mit sichtbaren Einschränkungen,
- **niedrig:** nur als Hinweis oder Arbeitsannahme,
- **unzureichend:** keine belastbare Entscheidung ohne weitere Prüfung.

Confidence darf nicht durch einen guten fachlichen Score ersetzt werden. Beispiel: Maturity 4,1 bei Confidence 38 bedeutet „wahrscheinlich gut aufgestellt, aber unzureichend belegt“.

7.3 Decision-specific Confidence

Ein Monatsbriefing kann mit mittlerer Confidence ausreichen. Eine Risikoakzeptanz, Vorstandsinvestition oder externe Bestätigung benötigt höhere Schwellen. Schwellenwerte werden pro Entscheidungstyp in der Governance festgelegt.

8. Risikoszenario und Risikoobjekt

8.1 Szenario statt abstraktem Schlagwort

Ein Risiko wird als nachvollziehbares Szenario modelliert:

Ursache/Bedrohung -> Schwäche oder Exposition -> Ereignis -> betroffene Assets/Prozesse -> geschäftliche Auswirkung

Pflichtfelder sind Scope, Risk Owner, betroffene Geschäftsziele, Zeitbezug, bestehende Controls, Quellen, Annahmen, inhärente Bewertung, Restrisikobewertung, Behandlungsentscheidung und Reviewdatum.

8.2 Risikoebenen

- **Szenariorisiko:** einzelnes konkretes Ereignisszenario.
- **Asset-/Prozessrisiko:** Verdichtung verbundener Szenarien für ein Objekt.
- **Themenrisiko:** z. B. Identity, Third Party, Ransomware oder Datenabfluss.
- **Portfolio- oder Unternehmensrisiko:** Managementsicht auf Konzentrationen und Toleranzverletzungen.

Aggregation bewahrt Drill-down und darf keine mathematische Addition nicht vergleichbarer Risiken vortäuschen.

8.3 Inhärent, aktuell und residual

- **Inhärentes Risiko:** Annahme ohne bestehende risikomindernde Controls.
- **Aktuelles Risiko:** reale Lage mit derzeitiger Exposition, Control-Zustand und aktuellen Signalen.
- **Ziel-Restrisiko:** erwartete Lage nach freigegebener Behandlung.
- **Beobachtetes Restrisiko:** nach Umsetzung und Wirksamkeitsprüfung tatsächlich neu bewertete Lage.

Diese vier Perspektiven verhindern, dass geplante Maßnahmen bereits als erreichte Wirkung gezählt werden.

9. Risikobewertungsmethoden

Die Plattform unterstützt mehrere versionierte Methoden. Ein Kunde wählt eine Primärmethode; parallele Methoden dürfen nur zu Analysezwecken genutzt werden.

9.1 Methode A - qualitative 5x5-Matrix

Likelihood und Impact werden jeweils von 1 bis 5 bewertet. Der Matrixwert dient Priorisierung. Impact kann aus mehreren Dimensionen bestehen, etwa Finanzen, Betrieb, Regulierung, Personen, Reputation und Strategie. Die höchste oder gewichtete relevante Dimension wird transparent ausgewiesen.

Stärken: verständlich, schnell, workshopfähig. **Grenzen:** ordinal, subjektiv, anfällig für Scheingenauigkeit und Score-Ballung.

9.2 Methode B - semi-quantitativ 0 bis 100

Likelihood, Exposure, Threat Activity, Business Impact und Control Effectiveness werden auf definierte Skalen normalisiert. Das Modell erzeugt Bänder, keine scheinpräzise Schadenswahrscheinlichkeit. Referenzlogik:

$\text{Current Risk} = \text{Inherent Risk} \times \text{Exposure Factor} \times (1 - \text{Combined Control Mitigation})$

Die Komponenten werden getrennt angezeigt. Combined Control Mitigation wird gedeckelt und berücksichtigt Überschneidungen sowie Abhängigkeiten; mehrere Controls dürfen nicht einfach addiert werden.

9.3 Methode C - finanzielle Quantifizierung

Optional können Eintrittsfrequenz und Verlustbandbreiten für ausgewählte Top-Risiken modelliert werden. Diese Methode ist nicht Voraussetzung des ersten Produkts und erfordert qualifizierte Daten, Kalibrierung und klare Unsicherheitskommunikation. Sie gehört in den Ideenparkplatz bzw. eine spätere Enterprise-Erweiterung.

9.4 Methoden-Governance

Methodenwechsel erzeugen keine stille Trendfortsetzung. Die Plattform speichert alte und neue Werte, berechnet eine Vergleichsbrücke und markiert Methodeneffekte. Schwellenwerte benötigen Owner, Freigabe, Gültigkeit und Reviewrhythmus.

10. Risikobereitschaft, Toleranzen und Eskalation

Risikobereitschaft wird nicht als ein globaler Satz hinterlegt. Sie wird nach Risikoart, Geschäftsservice, Auswirkungsdimension und Zeithorizont differenziert.

10.1 Toleranzobjekt

Ein Toleranzobjekt enthält:

- gültigen Scope,
- Risikokategorie,
- erlaubtes Band,
- harte und weiche Schwelle,
- zuständige Entscheidungsebene,
- notwendige kompensierende Controls,
- maximale Akzeptanzdauer,
- Eskalationsweg,
- genehmigende Rolle.

10.2 Eskalationslogik

- Unter Toleranz: operativ steuern und überwachen.
- Nahe Toleranz: Trendwarnung und Behandlungsoptionen.
- Über Toleranz: Entscheidungspflicht innerhalb definierter Frist.
- Kritische Überschreitung: sofortige Eskalation, ggf. Incident- oder Krisenprozess.
- Unzureichende Confidence: keine automatische Entwarnung; Datenlücke wird selbst zum Steuerungsthema.

10.3 Risikoakzeptanz

Eine Akzeptanz benötigt befristete Entscheidung, Begründung, Restrisiko, Alternativen, kompensierende Controls, Kosten-/Nutzenkontext und Reviewtermin. Ein Managed-Service-Anbieter kann die Entscheidung vorbereiten, nicht an Stelle der verantwortlichen Kundenrolle treffen.

11. Risikoaggregation und Konzentration

Ein Gesamtportfolio muss mehr zeigen als die Summe einzelner Ampeln. Die Plattform erkennt:

- gemeinsame Ursachen,
- Abhängigkeit von einem Lieferanten oder Identitätssystem,

- mehrere Risiken auf denselben kritischen Geschäftsservice,
- Controls mit hoher systemischer Bedeutung,
- Korrelation durch Region, Technologie, Person oder Prozess,
- gleichzeitige Fristen und Ressourcenengpässe,
- Risk Debt durch dauerhaft verschobene Behandlungen.

11.1 Aggregationsregeln

- keine einfache Summation ordinaler Scores;
- Kennzeichnung dominanter und systemischer Risiken;
- Darstellung von Toleranzverletzungen, Anzahl, Trend und Konzentration;
- separate Sicht auf maximale Einzelwirkung und kumulative Exposition;
- Drill-down bis zu Szenario, Quelle und Control;
- Confidence-Band für jede Verdichtung.

11.2 Portfolio-Heatmap

Die Heatmap ist nur eine Sicht. Ergänzend benötigt das Decision Center Top-Ursachen, betroffene Geschäftsservices, größte positive und negative Trends, unbewertete Exposition und Entscheidungsbedarf.

12. Threat Intelligence und Change Intelligence

Threat Intelligence umfasst externe und interne Signale, die die Risikolage verändern können. Dazu gehören beispielsweise:

- öffentlich bekannte Schwachstellen und Ausnutzungshinweise,
- Bedrohungsakteure, Kampagnen, Techniken und Branchenbezug,
- interne Incidents und Near Misses,
- Findings aus Scannern, Audits und Penetrationstests,
- regulatorische oder vertragliche Änderungen,
- Cloud-, Architektur- und Lieferantenänderungen,
- neue Produkte, Standorte oder Akquisitionen,
- Control-Ausfälle oder Evidence-Verfall.

Die Plattform ersetzt kein SIEM, SOC, EDR, Vulnerability Scanner oder Threat-Intelligence-Portal. Sie übersetzt deren Signale in ISMS-, Risiko-, Control- und Managementkontext.

12.1 Signalobjekt

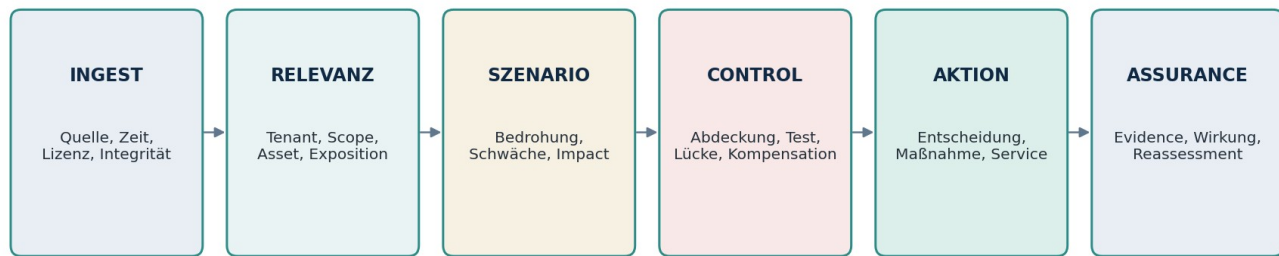
Ein Signal besitzt Quelle, Typ, Veröffentlichungs- und Erfassungszeit, Gültigkeit, Lizenz, Integrität, Schwere, Aktualität, betroffene Technologien oder Branchen, Rohreferenz, Normalisierung, Confidence und Verarbeitungsstatus.

12.2 Relevanz statt Alarmflut

Ein Signal wird erst zum Kundenthema, wenn mindestens ein begründeter Relevanzpfad existiert. Relevanz prüft:

5. technische oder organisatorische Anwendbarkeit,
6. Zugehörigkeit zum aktiven Scope,
7. Exposition und Erreichbarkeit,
8. Kritikalität betroffener Geschäftsservices,
9. vorhandene oder fehlende Controls,
10. aktive Ausnutzung oder beobachtete Ereignisse,
11. Aktualität und Qualität der Quelle,
12. Zielprofil und Risikotoleranz.

Vom externen Signal zur nachweisbaren Handlung



Jede Stufe speichert Begründung, Regelversion, Datenstand, Confidence und menschliche Übersteuerung.

13. Threat-Relevanzscore

Für den Demonstrator gilt ein erklärbarer Referenzscore von 0 bis 100:

Faktor	Referenzgewicht	Frage
Asset-/Scope-Match	20 %	Ist die betroffene Technologie oder Organisation im bestätigten Scope vorhanden?
Exposition	20 %	Ist das Objekt erreichbar, aktiv, ungepatcht oder anderweitig exponiert?
Business-Kritikalität	15 %	Welche geschäftliche Bedeutung besitzt das betroffene Objekt?
Exploitation-/Activity-Signal	15 %	Gibt es belastbare Hinweise auf aktive Ausnutzung oder relevante Kampagnen?
Control Gap	15 %	Fehlen relevante preventive, detective oder recovery Controls?
Recency und Source Confidence	10 %	Wie aktuell und belastbar ist das Signal?
Zielprofil-/Toleranzbezug	5 %	Berührt das Signal ein priorisiertes Ziel oder eine harte Toleranz?

Gewichte sind Startwerte. Der Score erzeugt Kategorien wie beobachten, prüfen, priorisieren und sofort handeln. Jede Kategorie zeigt die auslösenden Faktoren. Fehlende Assetdaten erhöhen nicht künstlich die Sicherheit; sie senken Confidence und können einen Discovery-Task auslösen.

13.1 Deduplizierung und Korrelation

Mehrere Feeds zum selben Sachverhalt werden zu einem kanonischen Signalcluster verbunden. Rohquellen bleiben sichtbar. Wiederholte Meldungen erhöhen nicht automatisch Schwere. Neue unabhängige Evidence kann Confidence erhöhen.

13.2 Ablauf und Verfall

Signale besitzen Status: eingegangen -> normalisiert -> gematcht -> relevant / nicht relevant / unklar -> analysiert -> behandelt -> überwacht -> geschlossen. Relevanz und Aktualität verfallen nach konfigurierbaren Regeln; eine geschlossene Meldung kann bei neuer Evidence wieder geöffnet werden.

14. Vulnerability Intelligence

Eine Schwachstelle wird nicht allein nach technischer Schwere priorisiert. Die Plattform kombiniert:

- technische Schwere und Angriffsvektor,
- beobachtete oder prognostizierte Ausnutzbarkeit,
- Asset- und Versionsmatch,
- Internet- oder Netzwerkexposition,
- Geschäfts- und Datenkritikalität,
- vorhandene Schutzmaßnahmen,
- Patch- oder Mitigationsverfügbarkeit,
- Change-Fenster und Betriebsrisiko,
- Abhängigkeiten und kompensierende Maßnahmen,
- Confidence des Matches.

14.1 Priorisierungsergebnis

Das Ergebnis ist keine bloße P1-P4-Klasse, sondern eine Decision Card mit:

- betroffenen Objekten und Geschäftsservices,
- Warum der Fall relevant ist,
- Handlungsfrist,
- verfügbaren Optionen,
- Risiko bei Nichtbehandlung,
- Betriebsrisiko der Behandlung,
- erforderlichen Freigaben,
- möglichem Managed Service,
- Evidence für Closure.

14.2 Kein falsches Asset-Matching

Heuristische Matches bleiben Kandidaten. Kritische automatische Zuordnungen benötigen bestätigte Produkt-/Versionsdaten oder menschliche Validierung. Ein unsicheres Match darf keine definitive Risikoaussage erzeugen.

15. Control Intelligence

Control Intelligence verbindet Anforderung, Control-Ziel, konkrete Implementierung, Scope, Owner, Evidence, Test, Findings, Risiken, Bedrohungen, Kosten und Wirkung.

15.1 Control-Lebenszyklus

vorgeschlagen -> anwendbar / nicht anwendbar -> geplant -> implementiert -> in Betrieb -> getestet -> wirksam / eingeschränkt / unwirksam -> verbessert / ersetzt / stillgelegt

Anwendbarkeit, Implementierung, Betrieb und Wirksamkeit sind getrennte Aussagen.

15.2 Control-360 oder Control Digital Passport

Jedes Control besitzt:

- Zweck und erwartete Schutzwirkung,
- Anforderungen und Framework-Mappings,
- Scope und Implementierungsvarianten,
- Owner und Betreiber,
- abhängige Technologien und Prozesse,
- preventive, detective, responsive oder recovery Funktion,
- Evidence-Anforderungen,
- Testplan und letzte Ergebnisse,
- Ausnahmen und kompensierende Controls,
- verbundene Risiken, Incidents und Findings,
- Kosten- und Kapazitätsindikatoren,
- Wirksamkeitstrend,
- Confidence und nächste sinnvolle Aktion.

15.3 Design versus Operating Effectiveness

- **Design Adequacy:** Kann das Control bei korrekter Umsetzung das beabsichtigte Risiko angemessen beeinflussen?

- **Implementation Completeness:** Ist es im erforderlichen Scope vollständig umgesetzt?
- **Operating Reliability:** Läuft es über Zeit und Population zuverlässig?
- **Outcome Effectiveness:** Belegen Tests und Outcomes eine tatsächliche Wirkung?

Diese Trennung verhindert, dass eine Richtlinie oder technische Konfiguration automatisch als wirksames Control gilt.

16. Referenzmodell für Control-Wirksamkeit

Für das Standardprofil gilt als transparente Ausgangslogik auf 0 bis 100:

$$\text{Control Effectiveness} = 0,15 \times \text{Design} + 0,25 \times \text{Implementation} + 0,20 \times \text{Operation} + 0,40 \times \text{Outcome}$$

Jede Facette wird über definierte Kriterien und Evidence bewertet. Outcome erhält das höchste Gewicht, weil tatsächliche Schutzwirkung wichtiger ist als Dokumentation. Bei Controls, deren Wirkung nur schwer direkt messbar ist, kann ein freigegebenes profilspezifisches Gewicht verwendet werden.

16.1 Coverage und Population

Wirksamkeit gilt immer für einen Scope. Ein Control kann in 90 % der Population funktionieren und trotzdem bei den kritischsten 10 % versagen. Daher zeigt die Plattform:

- abgedeckte Population,
- kritische Ausnahmen,
- betroffene Standorte oder Systeme,
- Teststichprobe,
- Fehlerrate,
- Zeitstabilität,
- Confidence.

16.2 Kombinierte Controls

Mehrere Controls können dasselbe Szenario beeinflussen. Kombinationen werden als Schutzschichten modelliert. Die Plattform berücksichtigt:

- Abhängigkeiten und gemeinsame Ausfallursachen,
- Überschneidungen,
- Reihenfolge preventive/detective/recovery,
- kompensierende Wirkung,
- Wirksamkeitsgrenzen,
- Nachweisstand.

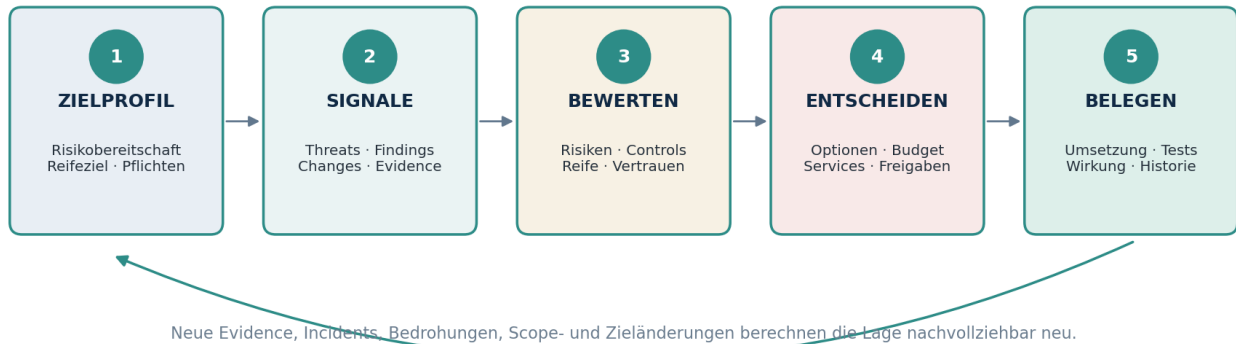
Control-Wirkungen werden nicht blind addiert. Das Regelmodell begrenzt maximale Mitigation und zeigt Annahmen.

16.3 Control Debt

Control Debt beschreibt dauerhaft bekannte, aber nicht nachhaltig gelöste Defizite: manuelle Workarounds, abgelaufene Ausnahmen, wiederholte Findings, fehlende Evidence, überlastete Owner oder technische Altlasten. Ein Control kann aktuell „funktionieren“, aber hohen Debt besitzen. Der Debt wird als eigener Trend im Portfolio gezeigt.

17. Zusammenspiel von Risiko, Reife, Threat und Control

Risk & Control Intelligence: ein erklärbarer Lern- und Entscheidungszyklus



17.1 Kausaler Pfad

13. Ein Signal oder Assessment verändert eine Annahme.
14. Die Plattform bestimmt betroffene Objekte und Scope.
15. Relevante Risikoszenarien werden erzeugt oder neu bewertet.
16. Verbundene Controls werden auf Abdeckung, Betrieb und Wirksamkeit geprüft.
17. Zielprofil, Toleranz und Reifegrad bestimmen Dringlichkeit und Nachweistiefe.
18. Optionen werden mit Wirkung, Aufwand, Abhängigkeiten und Confidence vorbereitet.
19. Eine autorisierte Rolle entscheidet.
20. Maßnahme, Service oder Akzeptanz wird umgesetzt.
21. Evidence und Tests belegen oder widerlegen die erwartete Wirkung.
22. Reife, Risiko und Zielroute werden versioniert aktualisiert.

17.2 Keine Kreisargumente

Reifegrad darf nicht steigen, nur weil ein Risikoscore gesunken ist. Risiko darf nicht sinken, nur weil ein Control als „implementiert“ markiert wurde. Control-Wirksamkeit darf nicht aus dem fehlenden Incident allein abgeleitet werden. Jede Dimension benötigt eigene Evidence und Kriterien.

17.3 Positive und negative Signale

Die Intelligenzschicht verarbeitet nicht nur Warnungen. Erfolgreiche Tests, geschlossene Findings, stabile Trends, verbesserte Datenqualität und resilient bewältigte Ereignisse können Confidence oder Wirksamkeit erhöhen. Positive Veränderungen werden ebenso erklärt wie Verschlechterungen.

18. Zielerreichung und Readiness

18.1 Goal Proximity Score

Der allgemeine **Goal Proximity Score** beschreibt, wie nah der Kunde seinem ausgewählten Zielprofil ist. Er ist profilabhängig und kann Reife, Risiko, Meilensteine, Control-Abdeckung, Evidence, Findings und Governance kombinieren. Er ersetzt keine Detailwerte.

Referenzdimensionen:

Dimension	Standardgewicht
Ziel-Capability-Erreichung	25 %
priorisierte Risikobehandlung	20 %

Dimension	Standardgewicht
Control-Abdeckung und Wirksamkeit	20 %
Evidence- und Datenvertrauen	15 %
Findings, Ausnahmen und Fristen	10 %
Governance und Entscheidungen	10 %

18.2 Audit- oder Assessment-Readiness

Readiness ist ein spezielles Zielfprofil. Die Referenzbewertung berücksichtigt:

- Scope-Stabilität und Vollständigkeit,
- Anforderungs- und Control-Abdeckung,
- aktuelle, geeignete Evidence,
- Control-Tests und Wirksamkeit,
- offene Findings und Ausnahmen,
- Rollen- und Terminbereitschaft,
- Management-Review und interne Prüfung,
- Datenvertrauen.

Ein hoher Readiness-Wert ist keine Zertifizierungsgarantie. Die Plattform zeigt explizit „vorbereitet auf Basis des aktuellen Datenstands“.

18.3 Route statt Status

Neben dem aktuellen Wert zeigt die Plattform:

- Zieltermin,
- prognostizierte Ankunft,
- kritischen Pfad,
- nächste Meilensteine,
- größte Blocker,
- Szenarien bei Budget- oder Kapazitätsänderung,
- erforderliche Entscheidungen.

Simulationen und Visualisierung werden in Dokument 10 vertieft.

19. Benchmarking und Vergleich

Benchmarking ist optional und erfordert strikte Vergleichbarkeit und Datenschutz.

19.1 Vergleichsgruppen

Mögliche Dimensionen sind Branche, Größe, Regulierungsintensität, Region, Zielfprofil, Cloud-Anteil, Betriebsmodell und Reife der Datengrundlage. Die Gruppe muss ausreichend groß und anonymisiert sein.

19.2 Zulässige Aussagen

- Perzentil einer Capability innerhalb einer vergleichbaren Population,
- typischer Aufwand oder Durchlaufzeit eines Prozesses,
- häufige Control-Lücken,
- übliche Zielreife,
- relative Entwicklung über Zeit.

Nicht zulässig sind scheinpräzise Aussagen aus kleinen oder verzerrten Stichproben, Rückschluss auf einzelne Mandanten oder eine normative Behauptung, der Median sei automatisch angemessen.

19.3 Cross-Tenant Learning

Mandantenübergreifende Learnings dürfen nur aus anonymisierten, aggregierten Mustern oder freigegebenen Referenzartefakten entstehen. Kundendaten, Risikoentscheidungen und vertrauliche Evidence bleiben strikt getrennt.

20. Erklärbarkeit, Overrides und Decision Records

Jeder Score oder Vorschlag besitzt einen **Explain Panel** mit:

- Aussage in Klartext,
- betroffenen Scope,
- wichtigsten Treibern,
- Gegenargumenten oder entlastenden Faktoren,
- Methode und Version,
- Datenquellen und Aktualität,
- Confidence und Datenlücken,
- alternativen Optionen,
- menschlichen Overrides,
- nächster Reviewfrist.

20.1 Override-Typen

- Datenkorrektur,
- fachliche Neubewertung,
- temporäre Ausnahme,
- Toleranzentscheidung,
- Methodenabweichung,
- Prioritätsänderung,
- bewusste Nichtbehandlung.

Overrides benötigen Rolle, Begründung, Gültigkeit und ggf. Freigabe. Die ursprüngliche Berechnung bleibt erhalten.

20.2 Entscheidungsartefakt

Ein Decision Record verbindet Entscheidung, Optionen, Empfehlung, erwartete Wirkung, Kosten, Risiken, Confidence, Entscheider, Datum, Bedingungen und Review. Das ermöglicht später die Frage: „War die damalige Entscheidung auf Basis der damaligen Daten plausibel?“

21. Automatisierung und KI-Grenzen

21.1 Deterministisch automatisierbar

- Scoreberechnung nach freigegebener Regelversion,
- Fristen, Staleness und Eskalationen,
- Signalnormalisierung und Deduplizierung,
- bestätigtes Asset-Matching über stabile IDs,
- Roll-ups und Trendberechnung,
- Workflow-Trigger,
- Evidence-Validierungen,
- Report- und Decision-Card-Befüllung.

21.2 KI-gestützt

- Zusammenfassung komplexer Treiber,
- Vorschlag von Risikoszenarien aus strukturierten Signalen,
- Entwurf von Maßnahmenalternativen,
- Ähnlichkeitssuche in freigegebenen Playbooks,
- Erklärung für verschiedene Rollen,
- Hinweis auf Widersprüche und Datenlücken.

21.3 Nicht autonom zulässig

- endgültige Risikoakzeptanz,
- rechtliche Konformitätsfeststellung,
- Zertifizierungsurteil,
- finanzielle Freigabe,
- automatische Änderung der Risikobereitschaft,

- definitive Zuordnung unsicherer Assets,
- Schließen eines Findings ohne Evidence,
- kundenübergreifende Nutzung vertraulicher Daten.

Alle KI-Ergebnisse sind als Vorschlag markiert und zeigen Modell, Zeitpunkt, Eingaben, Quellen, Confidence und menschlichen Reviewstatus. Details folgen in Dokument 20A.

22. Rollenbezogene Sichten

22.1 Executive

Sieht Zielerreichung, Toleranzverletzungen, Top-Geschäftsrisiken, Investitionsentscheidungen, Trend, Confidence und Wertbeitrag. Keine technische Alarmflut.

22.2 CISO / ISMS-Verantwortung

Sieht Risikoportfolio, Capability-Reife, Control-Engpässe, offene Entscheidungen, Datenlücken, Zielroute und Servicewirkung.

22.3 Control Owner

Sieht Scope, Verpflichtungen, erwartete Evidence, Tests, Findings, Exceptions, Population, nächste Aktion und Wirkung auf Risiken.

22.4 Specialist / SOC / Vulnerability Team

Sieht Rohsignal, technische Anwendbarkeit, Asset-Match, Exposition, Threat-Kontext, Control-Lücken und fachlichen Übergabestatus.

22.5 Berater und Managed-Service-Leitung

Sieht Mandantenportfolio, gemeinsame Muster, wiederverwendbare Playbooks, Kapazitätsbedarf, Eskalationen und fachlich begründete Service-Opportunities - ohne Cross-Tenant-Datenoffenlegung.

22.6 Auditor / Reviewer

Sieht Kriterien, Methodenversion, Evidence, Tests, Overrides, Historie, Stichproben und Confidence. Keine Black-Box-Werte.

23. End-to-End-Szenarien

23.1 Kritische Schwachstelle

23. Ein externer Feed liefert eine neue Schwachstelle mit Ausnutzungshinweis.
24. Die Plattform normalisiert und clustert Quellen.
25. Ein bestätigter Softwarebestand erzeugt einen Asset-Match; ein unsicheres System bleibt Kandidat.
26. Exposition und Geschäftsservice-Kritikalität erhöhen Relevanz.
27. Verbundene preventive und detective Controls werden geprüft.
28. Das aktuelle Risikoszenario steigt von „mittel“ auf „hoch“; Confidence ist 82.
29. Drei Optionen erscheinen: Patch im Wartungsfenster, temporäre Isolation, Managed Emergency Remediation.
30. Der Owner entscheidet, dokumentiert Betriebsrisiko und Freigabe.
31. Nach Umsetzung werden Patch-Evidence und Exposure-Test geprüft.
32. Das Restrisiko sinkt erst nach erfolgreicher Wirksamkeitsprüfung.

23.2 Zielreife statt Zertifizierung

Ein mittelständischer Kunde wählt für zwölf Monate Zielreife 3 in Identity, Incident und Supplier Security, aber keine Zertifizierung. Die Plattform priorisiert Capability-Lücken und Risikowirkung. Audit-spezifische Evidence-Anforderungen bleiben reduziert. Der Kunde erhält eine realistische Route statt einer maximalen Normencheckliste.

23.3 Audit-Readiness

Ein regulierter Kunde aktiviert ein Readiness-Profil mit festem Termin. Die Plattform zeigt stabile Reife, aber unzureichende Evidence-Aktualität in zwei Controls. Der Readiness-Wert bleibt daher unter dem Reifegrad. Der Berater generiert gezielte Evidence-Aufgaben und ein Management-Deck, statt pauschal neue Controls einzuführen.

23.4 Control wirkt nur teilweise

MFA ist formal implementiert, aber 18 % der privilegierten Konten liegen außerhalb des Scopes und der letzte Test zeigt Ausnahmen. Implementierung ist hoch, Coverage und Outcome sind eingeschränkt. Das Control wird nicht als vollständig wirksam dargestellt; Risiko und Goal Proximity spiegeln die kritische Population.

23.5 Datenlücke als Managementthema

Ein Kunde besitzt hohe gemeldete Reife, aber veraltete Assetdaten und überwiegend Selbstauskünfte. Die Plattform zeigt Reife 3,8 bei Confidence 41. Die tägliche Mission priorisiert nicht sofort neue Controls, sondern zuerst Datenbasis, Owner und unabhängige Tests.

23.6 Service-Opportunity mit Alternativen

Wiederholte Control-Tests scheitern wegen fehlender interner Kapazität. Das System zeigt drei Wege: internen Owner aufbauen, Prozess automatisieren oder Managed Control Assurance buchen. Wirkung, Aufwand und Abhängigkeiten werden verglichen. Der Service ist eine begründete Option, nicht die einzig sichtbare Lösung.

24. Fehler- und Sonderfälle

Fall	Verbindliches Verhalten
Widersprüchliche Quellen	Konflikt sichtbar machen; keine stille Auswahl ohne Prioritätsregel.
Veraltete Evidence	Scorehistorie erhalten, Confidence senken, Review auslösen.
Fehlender Owner	Bewertung darf vorbereitet, aber nicht final freigegeben werden.
Unsicherer Asset-Match	Kandidat markieren; kritische Aktion erfordert Bestätigung.
Methodenversion geändert	Trendbruch und Vergleichsbrücke anzeigen.
Scope geändert	betroffene Scores neu baselinen; alte Historie bewahren.
Signalquelle ausgefallen	letzten Datenstand, Ausfall und Confidence-Auswirkung zeigen.
Control-Test widerspricht Self Assessment	unabhängigen Test priorisieren; Konflikt und Review anlegen.
Risiko über Toleranz ohne Budget	Managemententscheidung und dokumentierte Übergangsmaßnahme erzwingen.
Zu kleine Benchmarkgruppe	keinen Vergleichswert zeigen.
KI nicht verfügbar	deterministische Kernlogik und manuelle Bearbeitung bleiben funktionsfähig.
False Positive	Begründete Verwerfung speichert Lern- und Matchinginformation.

25. KPIs für die Intelligenzschicht

25.1 Qualitäts-KPIs

- Anteil kritischer Scores mit hoher oder mittlerer Confidence,
- Anteil veralteter Evidence,
- Zeit bis zur Bestätigung eines kritischen Signals,
- False-Positive- und False-Negative-Rate bei Matchingregeln,
- Anteil manueller Overrides mit fristgerechtem Review,
- Reproduzierbarkeit historischer Bewertungen,
- Abdeckung kritischer Assets mit Owner und Risiko-/Control-Beziehungen.

25.2 Wirkungs-KPIs

- Zeit von Signal bis Entscheidung,
- Zeit von Entscheidung bis geprüfter Wirkung,
- Reduktion überfälliger Toleranzverletzungen,
- Anteil Maßnahmen mit nachgewiesener statt nur erwarteter Wirkung,
- Verbesserung priorisierter Capabilities,
- gesparte Analyse- und Reportingzeit,
- Wiederverwendungsquote freigegebener Playbooks,
- vermiedene unnötige Maßnahmen durch bessere Relevanzfilterung.

25.3 Anti-KPIs

Die Plattform optimiert nicht auf möglichst viele Risiken, Alerts, Maßnahmen, Scores oder Servicebuchungen. Solche Mengen können schlechte Daten, Alarmflut oder künstliche Komplexität anzeigen.

26. Globale Akzeptanzkriterien

- **09-AC01:** Jeder sichtbare Score besitzt Scope, Zielbezug, Methode, Version, Datenstand und Confidence.
- **09-AC02:** Reifegrad, Risiko, Control-Wirksamkeit und Confidence sind getrennt speicher- und darstellbar.
- **09-AC03:** Geplante Maßnahmen reduzieren kein beobachtetes Restrisiko vor Wirksamkeitsprüfung.
- **09-AC04:** Kritische Threat-Signale können bis Quelle, Asset-Match, Risikoszenario, Control und Entscheidung verfolgt werden.
- **09-AC05:** Unsichere Matches und Datenlücken werden nicht als bestätigte Tatsachen dargestellt.
- **09-AC06:** Jede manuelle Übersteuerung bleibt mit Begründung, Rolle, Zeit und Gültigkeit nachvollziehbar.
- **09-AC07:** Methoden- und Gewichtungsänderungen sind versioniert; historische Werte bleiben reproduzierbar.
- **09-AC08:** Risikoakzeptanzen oberhalb definierter Schwellen benötigen die richtige menschliche Freigabe.
- **09-AC09:** Ein Zielfprofil kann ohne Audit- oder Zertifizierungsziel betrieben werden.
- **09-AC10:** Readiness wird nicht mit Reife gleichgesetzt und nicht als Zertifizierungsgarantie bezeichnet.
- **09-AC11:** Control-Wirksamkeit berücksichtigt Scope/Population, Test und Outcome.
- **09-AC12:** Externe Signale erzeugen nicht automatisch Aufgaben für alle Mandanten, sondern durchlaufen Relevanzprüfung.
- **09-AC13:** Der Kernbetrieb bleibt bei KI-Ausfall nutzbar.
- **09-AC14:** Benchmarking wird nur bei ausreichender Vergleichbarkeit und Anonymität angezeigt.
- **09-AC15:** Jede Managemententscheidung kann mit damaligem Datenstand rekonstruiert werden.

27. Festgelegte Entscheidungen

- **09-D01:** Die Plattform verwendet keine einzige universelle Sicherheitskennzahl.
- **09-D02:** Reife, Risiko, Control-Wirksamkeit und Confidence sind eigenständige Dimensionen.
- **09-D03:** Das Referenz-Reifegradmodell nutzt Stufen 0 bis 5 und die Facetten Design, Implementierung, Betrieb und Wirksamkeit.
- **09-D04:** Zielreife wird pro Capability und Zielprofil festgelegt; maximale Reife ist kein Standardziel.
- **09-D05:** Risiko wird als Szenario mit Ursache/Threat, Schwäche/Exposition, Ereignis und Business Impact modelliert.
- **09-D06:** Inhärentes, aktuelles, Ziel- und beobachtetes Restrisiko werden getrennt geführt.
- **09-D07:** Threat- und Vulnerability-Signale werden über Tenant-, Scope-, Asset-, Expositions- und Control-Relevanz gefiltert.
- **09-D08:** Control-Implementierung und Control-Wirksamkeit werden nicht gleichgesetzt.
- **09-D09:** Scores und Empfehlungen sind versioniert, erklärbar und menschlich übersteuerbar.
- **09-D10:** Confidence wird kontext- und entscheidungsspezifisch bewertet.
- **09-D11:** Geplante Maßnahmen zählen erst nach Evidence und Wirksamkeitsprüfung als erreichte Wirkung.
- **09-D12:** Risk Appetite und Toleranz sind differenziert, befristet und mit Entscheidungsrechten verknüpft.
- **09-D13:** Serviceempfehlungen müssen Alternativen und fachliche Begründung zeigen.
- **09-D14:** Der Demonstrator verwendet transparente Referenzgewichtungen, die später konfigurierbar sind.
- **09-D15:** Audit-Readiness ist ein spezielles Zielprofil, nicht die primäre Gesamtlogik.
- **09-D16:** Cross-Tenant Learning ist nur anonymisiert, aggregiert oder über freigegebene Referenzartefakte zulässig.
- **09-D17:** Wesentliche Freigaben bleiben menschliche Entscheidungen.
- **09-D18:** Historische Bewertungen bleiben mit damaliger Methode und Datenlage rekonstruierbar.

28. Begründete Annahmen

- **09-A01:** Ein semi-quantitatives Modell ist für den Demonstrator verständlicher und implementierbarer als eine vollständige finanzielle Quantifizierung.
- **09-A02:** Kunden akzeptieren konfigurierbare Referenzmodelle, wenn Berechnung und Grenzen transparent sind.
- **09-A03:** Ein erheblicher Teil heutiger Fehlpriorisierung entsteht durch fehlenden Geschäfts-, Asset- und Control-Kontext.
- **09-A04:** Evidence-Aktualität und unabhängige Tests verbessern die Aussagekraft stärker als zusätzliche Selbstauskunftsfelder.
- **09-A05:** Threat-Signale können aus öffentlichen, kommerziellen und kundeneigenen Quellen normalisiert werden, sofern Lizenzen und Herkunft beachtet werden.
- **09-A06:** Die Strategie-DNA kann Schwellen und Gewichtungen beeinflussen, ohne jeden Kunden in ein vollständig individuelles Modell zu zwingen.
- **09-A07:** Roll-ups benötigen kritikalitätsbasierte Ausnahmen, damit Durchschnittswerte keine wesentlichen Defizite verdecken.
- **09-A08:** Nutzer verstehen Confidence besser, wenn Treiber und Datenlücken sichtbar sind, statt nur eine Prozentzahl zu sehen.
- **09-A09:** Managed-Service-Opportunities werden eher akzeptiert, wenn interne Alternativen gleichberechtigt dargestellt werden.
- **09-A10:** Der digitale Zwilling liefert genügend Beziehungen, um Ursache-Wirkungs-Pfade im Prototyp glaubwürdig zu simulieren.
- **09-A11:** Für synthetische Demo-Unternehmen können konsistente Threat-, Risk-, Control- und Maturity-Daten erzeugt werden.
- **09-A12:** Benchmarking wird zunächst mit synthetischen oder ausdrücklich freigegebenen Referenzdaten demonstriert.

29. Offene Fragen

- **09-O01:** Welche Primärmethode wird für jedes Demo-Unternehmen verwendet: 5x5 oder semi-quantitativ?
- **09-O02:** Welche Capability-Taxonomie ist für die erste Produktversion verbindlich?
- **09-O03:** Welche Confidence-Schwellen gelten je Entscheidungstyp?
- **09-O04:** Welche Weighting-Parameter dürfen Kunden selbst ändern und welche nur Administratoren oder Method Owners?
- **09-O05:** Wie werden Control-Abhängigkeiten und gemeinsame Ausfallursachen im ersten Regelmodell vereinfacht?
- **09-O06:** Welche Signalquellen werden im Prototyp real integriert und welche nur simuliert?
- **09-O07:** Welche Standard-Toleranzkategorien und Eskalationsstufen werden ausgeliefert?
- **09-O08:** Welche historische Vergleichslogik wird bei Methodenwechsel technisch umgesetzt?
- **09-O09:** Welche Mindestgröße und Anonymitätsregeln gelten für echte Benchmarks?
- **09-O10:** Wie tief soll finanzielle Risikoquantifizierung in einer späteren Version gehen?
- **09-O11:** Welche regulatorischen oder branchenspezifischen Profile benötigen eigene Scorelogik?

- **09-O12:** Welche Rollen dürfen Bewertungen, Overrides und Methoden freigeben?
- **09-O13:** Wie wird die Qualität automatisch generierter Risikoszenarien gemessen?
- **09-O14:** Welche Performanceziele gelten für Recalculation bei großen Graphen und Portfolioansichten?
- **09-O15:** Wie werden Services bewertet, deren Wirkung nur langfristig oder indirekt sichtbar ist?

30. Ideenparkplatz

- Monte-Carlo- oder FAIR-nahe finanzielle Quantifizierung für ausgewählte Top-Risiken.
- Cyber-Digital-Twin-Simulationen mit zeitabhängigen Angriffspfaden.
- Control Digital Passport als portables, maschinenlesbares Assurance-Artefakt.
- Branchenbezogene Threat-Relevance-Modelle und Playbooks.
- Privacy-preserving Benchmarking über mehrere Betreiber.
- Kausale Lernmodelle, die erwartete und beobachtete Maßnahmenwirkung vergleichen.
- Confidence Budget: zeigt, welche zusätzliche Evidence den größten Erkenntnisgewinn bringt.
- Risk Debt und Control Debt als strategische Bilanz über mehrere Jahre.
- „Pre-Mortem“-Simulation: Welche Zielannahme könnte den Plan scheitern lassen?
- Autonomer Watcher für Methoden- und Datenqualitätsdrift, ohne Entscheidungsautonomie.
- Szenariobibliothek mit Community- oder Partnerpaketen.
- Versicherungs- oder Vertragskontext als zusätzliche Behandlungsoption.
- Entscheidungsqualität-Review: Vergleich damaliger Prognose mit später beobachteter Wirkung.

31. Dokumentenabhängigkeiten

- **Dokument 00:** Status, Begriffe und globale Governance.
- **Dokument 01:** Produktvision, Nutzen und wirtschaftliche Zielrichtung.
- **Dokument 03/04:** Rollen, Situationen und Nutzerreisen.
- **Dokument 05:** Module M11, M17 und M18 sowie globale Funktionsgrenzen.
- **Dokument 06:** Explainability, Confidence Badge, Decision Cards und rollenbezogene Darstellung.
- **Dokument 07:** Objekte, Beziehungen, Historie, Provenance und Confidence-Felder.
- **Dokument 08:** Risiko-, Control-, Assurance-, Incident-, Audit- und Managementprozesse.
- **Dokument 10:** Decision Center, KPIs, Zielrouten, Investitions- und What-if-Simulationen.
- **Dokument 12:** Reporting und zielgruppengerechte Erklärung der Bewertungen.
- **Dokument 13 bis 16:** Managed-Service-Delivery, Servicekatalog, Beraterbetrieb und Onboarding.
- **Dokument 17:** Signalquellen, Konnektoren und Automatisierungsregeln.
- **Dokument 18:** Berechnungsdienste, Eventarchitektur, Persistenz und Skalierung.
- **Dokument 19:** Rollen, Rechte, Audit Logs, Datenschutz und Mandantentrennung.
- **Dokument 20A:** KI-Vorschläge, Guardrails, Evaluation und Fallback.
- **Dokument 20C:** Tests, versionierte Regeln, Checkpoints und technische Umsetzung.

32. Änderungsprotokoll

Version	Datum	Änderung	Status
1.0	21.07.2026	Erstfassung des Reifegrad-, Risiko-, Threat-, Control- und Confidence-Modells	Erstellt